ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.03

BIA: consolidación de procesos críticos

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.03 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo..... 3
2. Instrucciones de uso..... 3
3. BIA: consolidación de procesos críticos..... 3
B.1 Métricas de tiempo y criticidad (procesos ordenados por puntaje)..... 4
B.2 Cuantificación (salida propia del BIA)..... 5
B.3 Estacionalidad y procedimientos alternos..... 7
B.4 Puntos únicos de falla y brechas que pasan a la matriz de riesgos..... 7
B.5 Supuestos y sensibilidad..... 8
Supuestos declarados en este entregable..... 8
Cierre de la consolidación..... 9

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3
Integrantes	Seis, con los cinco roles cubiertos
Fecha de entrega	viernes 16 de octubre de 2026 (H2)
Versión del documento	v1.0

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.03 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E03_BIA_Consolidacion_Procesos_Criticos_<Equipo>.docx (o .pdf).

3. BIA: consolidación de procesos críticos

El análisis de impacto al negocio (BIA) determina qué procesos son críticos, cuánto tolera la organización su interrupción y cuánto cuesta cada unidad de tiempo de indisponibilidad. El método oficial del proyecto es el de la **Guía del Estudiante del BIA** (asignación de la Semana 2): trece pasos en este orden: (1) preparar y levantar los datos con entrevista, cuestionario, taller, validación con el dueño del proceso y aprobación de la dirección; (2) inventariar los procesos; (3) fijar las métricas de tiempo MTPD (también llamado MTD), RTO, WRT, RPO y MBCO con la comprobación RTO + WRT ≤ MTPD; (4) valorar el impacto en cinco categorías (financiero, operativo, legal y regulatorio, reputacional y seguridad de las personas) en cinco cortes (4 h, 24 h, 72 h, 1 semana, 1 mes) y derivar el MTPD del umbral de tolerancia; (5) registrar la estacionalidad y el procedimiento alterno con su duración máxima sostenible; (6) mapear las seis clases de dependencia, el recurso mínimo de recuperación y los puntos únicos de falla; (7) priorizar con un puntaje explícito; (8) cuantificar AV, EF, SLE = AV × EF y el costo de la indisponibilidad por hora y por día; (9) fijar la frontera con el análisis de riesgos; (10) justificar el control en cinco pasos con ACC y ROSI; (11) declarar el método de valoración; (12) someter los supuestos al análisis de sensibilidad; (13) redactar el informe ejecutivo. Fundamento: ISO 22301:2019, ISO/TS 22317:2021 y NIST SP 800-34 Rev. 1. Los pasos 9 y 10 (ARO, ALE, cinco pasos de justificación, ACC y ROSI) se ejecutan en el proyecto dentro de la matriz de riesgos, entregable E.05, porque requieren estimar la frecuencia de la amenaza.

El BIA se desarrolla sobre las siete plantillas del BIA y se entrega en E.03 como un solo paquete: esta hoja de consolidación más los siete archivos como anexos obligatorios.

Plantilla del BIA	Paso de la Guía BIA	Contenido que aporta a la consolidación
BIA_P01_Inventario_Procesos	1–2	El censo de procesos del alcance de E.02: nombre, área, dueño, servicio, quién lo recibe, sistemas y ventana de operación; método de levantamiento usado.
BIA_P02_Ficha_BIA_Proceso	3–5	Una ficha por proceso crítico de la precalificación, y sus secciones 3, 8 y 9 para el proceso importante con los datos personales de la ficha: MTPD, RTO, WRT, RPO, MBCO con la comprobación; impacto por categoría y corte; estacionalidad; procedimiento alterno y duración máxima sostenible.
BIA_P03_Matriz_Impacto_Tiempo	4	Por proceso crítico, la matriz de impacto (cinco categorías × cinco cortes) y el umbral de tolerancia que deriva el MTPD.
BIA_P04_Mapa_Dependencias_Recursos	6	Por proceso crítico, las seis clases de dependencia, el recurso mínimo de recuperación al nivel del MBCO y las interdependencias entre procesos.
BIA_P05_Matriz_Criticidad_Priorizacion	7	La precalificación de todo el censo en el corte de 24 horas, los pesos por categoría acordados con la dirección, el puntaje de criticidad y la lista única ordenada.
BIA_P06_Registro_Supuestos_SPOF_Brechas	6, 11, 12	Los supuestos con origen y fecha, los supuestos y límites del método de valoración (el método se declara en la sección 10 de BIA_P02), los puntos únicos de falla, las brechas y los tres escenarios de sensibilidad.
BIA_P07_Informe_Ejecutivo	8, 13	Las nueve secciones del informe: resumen ejecutivo, alcance y método, procesos priorizados, costo de la indisponibilidad, puntos únicos de falla y brechas, frontera con el análisis de riesgos, justificación del control, análisis de sensibilidad, recomendaciones y aprobación.

Ejemplo resuelto de cátedra · entrega: viernes 16 de octubre de 2026 (H2). Se entrega como paquete único: esta hoja de consolidación más los siete anexos BIA_P01 a BIA_P07.

B.1 Métricas de tiempo y criticidad (procesos ordenados por puntaje)

Proceso	Dueño	Puntaje de criticidad	Clasificación	MTPD (MTD)	RTO	WRT	RPO	MBCO
P-01 Operación de la Red de Control (SCADA/OT)	Ing. René Alfaro, Gerente de Operaciones de Red	6,31	Crítico	4 h	2 h	1,5 h	15 min	Operación manual de las doce subestaciones principales con radio troncalizado, sin reconfiguración automática
P-03 Sistema de Gestión de Interrupciones (OMS)	Ing. René Alfaro, Gerente de Operaciones de Red	4,62	Crítico	8 h	4 h	3 h	1 h	Despacho de cuadrillas con planillas impresas y avisos por el centro de contacto
P-09 Gestión de TI corporativa	Ing. Carlos Iraheta, Jefe de TI/TO	2,80	Importante	24 h	8 h	4 h	4 h	Autenticación local de emergencia y correo en modo básico
P-06 Gestión de campo y cuadrillas con GIS	Ing. Sonia Portillo, Gerente Técnica	2,59	Importante	48 h	24 h	8 h	8 h	Órdenes de trabajo en planilla impresa con despacho por radio
P-04 Sistema Comercial y de Facturación	Lic. Marta Rodríguez, Gerente Comercial	2,46	Importante	72 h	24 h	24 h	4 h	Facturación con lectura estimada del ciclo anterior para el 100 % de los clientes regulados

Proceso	Dueño	Puntaje de criticidad	Clasificación	MTPD (MTD)	RTO	WRT	RPO	MBCO
P-02 Gestión de Medición Inteligente (AMI)	Ing. Sonia Portillo, Gerente Técnica	2,46	Importante	48 h	24 h	12 h	6 h	Lectura manual del 15 % de clientes de mayor consumo y estimación para el resto
P-05 Atención al cliente y centro de contacto	Lic. Marta Rodríguez, Gerente Comercial	1,93	Importante	24 h	8 h	4 h	8 h	Atención telefónica con registro manual de avisos
P-10 Contabilidad y reportes regulatorios	Lic. Julio Menéndez, Gerente de Finanzas	1,65	Diferible	1 semana	72 h	24 h	24 h	Cierre contable diferido con hoja de cálculo controlada
P-08 Nómina y administración de personal	Lic. Julio Menéndez, Gerente de Finanzas	1,65	Diferible	1 semana	72 h	24 h	24 h	Pago con la planilla del período anterior y ajuste posterior
P-07 Compras y contratación de terceros	Lic. Julio Menéndez, Gerente de Finanzas	1,60	Diferible	2 semanas	1 semana	24 h	24 h	Órdenes de compra en papel con aprobación por correo

Comprobación obligatoria en cada fila: RTO + WRT ≤ MTPD (2 + 2 = 4 ≤ 4 en el ejemplo). Clasificación: crítico / importante / diferible, según el puntaje de BIA_P05.

Comprobación RTO + WRT ≤ MTPD, fila por fila: P-01 2 + 1,5 = 3,5 ≤ 4 · P-03 4 + 3 = 7 ≤ 8 · P-04 24 + 24 = 48 ≤ 72 · P-02 24 + 12 = 36 ≤ 48 · P-09 8 + 4 = 12 ≤ 24 · P-06 24 + 8 = 32 ≤ 48 · P-05 8 + 4 = 12 ≤ 24 · P-10 y P-08 72 + 24 = 96 ≤ 168 · P-07 168 + 24 = 192 ≤ 336. Los diez procesos cumplen.

B.2 Cuantificación (salida propia del BIA)

Proceso · escenario (SLE-nn)	Costo por hora (USD)	Costo por día (USD)	Componentes del costo por hora	AV (USD)	EF	SLE = AV × EF (USD)	Método de valoración (BIA_P02 §10)
P-01 Operación de la Red de Control (SCADA/OT) · cifrado o manipulación del entorno SCADA (SLE-01)	62 000	1 488 000	Energía no suministrada, personal de campo y horas extra, compensaciones a clientes industriales, operación manual y soporte de emergencia del fabricante	9 000 000	0,55	4 950 000	Cuantitativo con datos y derivaciones de la ficha de datos del cliente y el supuesto S-12
P-03 Sistema de Gestión de Interrupciones (OMS) · indisponibilidad por cifrado de la plataforma (SLE-02)	18 500	444 000	Penalización por tiempo de restauración, cuadrillas improductivas, refuerzo del centro de contacto	2 600 000	0,50	1 300 000	Cuantitativo con supuestos declarados
P-04 Sistema Comercial y de Facturación (importante) · indisponibilidad del sistema comercial (SLE-03)	7 400	177 600	Facturación diferida, personal comercial improductivo, refuerzo del centro de contacto	3 100 000	0,45	1 395 000	Cuantitativo con supuestos declarados

Proceso · escenario (SLE-nn)	Costo por hora (USD)	Costo por día (USD)	Componentes del costo por hora	AV (USD)	EF	SLE = AV × EF (USD)	Método de valoración (BIA_P02 §10)
P-02 Gestión de Medición Inteligente (AMI) (importante) · indisponibilidad de la cabecera AMI (SLE-04)	2 900	69 600	Lectura manual, estimación de consumo, reprocesos del ciclo	1 200 000	0,40	480 000	Cuantitativo con supuestos declarados
P-04 Sistema Comercial y de Facturación (importante) · exposición de los datos personales de los clientes (SLE-05)	—	—	Notificación a los titulares	105 000	1,0	105 000	Cuantitativo con datos de la ficha: 420 000 clientes × USD 0,25 de notificar a cada uno
P-05 Atención al cliente y centro de contacto (importante) · exposición de los datos personales de los clientes que consulta en SAP IS-U (SLE-06)	—	—	Notificación a los titulares	105 000	1,0	105 000	Cuantitativo con datos de la ficha: 420 000 clientes × USD 0,25 de notificar a cada uno

El SLE se calcula para cada proceso crítico y para cada proceso importante que trata los datos personales que cuantifica la ficha de datos del cliente. En estos últimos el escenario es la exposición de los datos: AV = número de titulares de la ficha × costo de notificar a un titular de la ficha, más los otros costos por titular que la ficha cuantifica, y EF = proporción de titulares expuestos. Un mismo proceso admite una fila por escenario (cifrado o indisponibilidad, exposición de datos, fraude, sabotaje de la operación), cada una con su identificador SLE-nn, que E.05 cita en la tabla D.6. El método de valoración se declara en la sección 10 de BIA_P02, y BIA_P06 registra solo sus supuestos.

Aquí termina el BIA. La tasa anualizada de ocurrencia (ARO), la pérdida anual esperada (ALE = SLE × ARO), la justificación del control en cinco pasos, el ACC y el ROSI se calculan en E.05 (tabla D.6) con estos valores de SLE como insumo.

SLE-05 y SLE-06 aplican la regla de la guía para los procesos con los datos personales que cuantifica la ficha: AV = 420 000 clientes × USD 0,25 = USD 105 000 y EF = 1 para la exposición de toda la base; la ficha no cuantifica otros costos por titular. E.05 cita en su tabla D.6 el SLE del escenario que corresponde a cada riesgo. P-04 y P-02 resultaron importantes en BIA_P05 y conservan SLE-03 y SLE-04 porque E.05 cuantifica con ellos los riesgos R-07 y R-04.

Costo al alcanzar el MTPD: P-01 USD 248 000 (4 h) · P-03 USD 148 000 (8 h) · P-04 USD 532 800 (72 h) · P-02 USD 139 200 (48 h). Las cifras corresponden al escenario de temporada de lluvias declarado en BIA_P02; el escenario promedio anual del proceso de control de red rinde USD 38 750 por hora.

B.3 Estacionalidad y procedimientos alternos

Proceso	Períodos pico	Procedimiento alterno	Duración máxima sostenible	Recurso mínimo de recuperación (MBCO)
P-01 Operación de la Red de Control (SCADA/OT)	Temporada de lluvias de mayo a octubre (2,2 × en fallas simultáneas); demanda máxima diaria de 18:00 a 21:00	Operación manual con personal desplazado a subestación, maniobra ordenada por radio y registro en formulario F-OP-12	12 h, con un solo relevo disponible	12 operadores de campo, 2 coordinadores, 1 ingeniero SCADA, 2 estaciones HMI, radio troncalizado con batería y diagramas unifilares impresos
P-03 Sistema de Gestión de Interrupciones (OMS)	Temporada de lluvias (2,8 × en volumen de avisos)	Planillas impresas de despacho, radio y corte de reporte cada dos horas	24 h, con dos relevos	6 despachadores, radio troncalizado, planillas y mapa impreso de la red
P-04 Sistema Comercial y de Facturación (importante)	Cierre de ciclo mensual (1,9 ×)	Estimación de consumo con el ciclo anterior y emisión diferida	7 días, antes de comprometer el flujo de caja	8 analistas comerciales, acceso de solo lectura al histórico de consumo y capacidad de impresión
P-02 Gestión de Medición Inteligente (AMI) (importante)	Cierre de ciclo diario a las 02:00 y facturación mensual (1,5 ×)	Lectura manual programada del 15 % de clientes de mayor consumo	15 días, antes de comprometer el ciclo de facturación	20 lectores de campo con terminal portátil y rutas impresas

B.4 Puntos únicos de falla y brechas que pasan a la matriz de riesgos

Proceso	Clase de dependencia	Punto único de falla o brecha (de BIA_P06)	Se traslada a E.05 como (ID en la versión 1.1)
P-01 SCADA/OT	Aplicaciones y sistemas · Instalaciones	B-02: puntos de conexión entre la red de TI y la red OT sin filtro documentado, con el aislamiento declarado como no real	Vulnerabilidad del riesgo R-01
P-01 SCADA/OT	Proveedores y terceros	SPOF-04 / B-05: acceso remoto de mantenimiento del proveedor sin multifactor ni registro	Vulnerabilidad del riesgo R-02
P-01 SCADA/OT	Datos y registros vitales	SPOF-08 / B-01: respaldo semanal en cinta, sin copia aislada ni prueba de restauración	Vulnerabilidad del riesgo R-06 y agravante del impacto de R-01
P-01, P-02	Aplicaciones y sistemas	B-03 / B-04: sin inventario de activos OT ni monitoreo de seguridad en esa red	Vulnerabilidad del riesgo R-03
P-01 SCADA/OT	Personas y competencias críticas	SPOF-01 / B-08: un solo ingeniero con competencia de administración del SCADA	Vulnerabilidad del riesgo R-14
P-01, P-03	Instalaciones	SPOF-02: centro de control sin redundancia geográfica ni puesto de mando equipado	Agravante del impacto de R-01 y R-06
P-01 SCADA/OT	Aplicaciones y sistemas	SPOF-03: autenticación de los operadores dependiente del directorio corporativo de TI	Vulnerabilidad del riesgo R-07
P-02 AMI	Equipamiento y servicios básicos	SPOF-05: un único concentrador de datos por zona, sin reserva	Vulnerabilidad del riesgo R-04
P-04 Sistema Comercial	Proveedores y terceros	SPOF-06: enlace único con la pasarela de pagos	Vulnerabilidad del riesgo R-13
P-01, P-03, P-06	Equipamiento y servicios básicos	SPOF-07: repetidor de radio sin respaldo de energía	Vulnerabilidad del riesgo R-11
P-01 SCADA/OT	Aplicaciones y sistemas	B-06: sin ventana de mantenimiento ni proceso de parcheo en el entorno OT	Vulnerabilidad del riesgo R-12
P-01, P-02	Instalaciones	B-07: videovigilancia de subestaciones excluida, con convergencia no resuelta hacia la red OT	Vulnerabilidad del riesgo R-11

B.5 Supuestos y sensibilidad

Supuesto	Origen y fecha	Escenario mínimo	Escenario esperado	Escenario máximo	Variable que gobierna la conclusión
S-08 (sin uso) · Ingresos no percibidos por hora sin telecontrol, derivados de la ficha: 190 MW × USD 200 por MWh	Ficha de datos del cliente, bloque «Economía»: demanda de 120 a 275 MW	USD 24 000	USD 38 000	USD 55 000	No
S-09 (sin uso) · Compensaciones contractuales por hora, dato de la ficha	Ficha de datos del cliente, bloque «Operación por proceso»	USD 2 000	USD 4 500	USD 9 000	No
S-10 (sin uso) · AV del proceso de control de red, derivado de la ficha: USD 6,0 M de margen más USD 3,0 M de reposición	Ficha de datos del cliente, bloque «Economía»	USD 6 500 000	USD 9 000 000	USD 12 000 000	Sí
S-12 · EF del evento de referencia sobre el SCADA	Criterio del dueño del proceso y costo por día, 8 oct 2026	0,40	0,55	0,70	Sí
S-13 (sin uso) · Duración máxima sostenible del procedimiento alterno, dato de la ficha	Ficha de datos del cliente, bloque «Operación por proceso»; el simulacro de marzo de 2026 lo sostuvo 8 h	8 h	12 h	16 h	Sí
S-06 (sin uso) · Número de subestaciones principales, dato de la ficha	Ficha de datos del cliente, bloque «Economía»	8	12	20	No
S-14 · Presupuesto de seguridad de 2028 y 2029 igual al de 2027	Ficha de datos del cliente (rango de USD 300 000 a 600 000 que declara la Junta Directiva)	USD 300 000	USD 480 000	USD 600 000	Sí, sobre el roadmap de E.10

Regla de calidad: cada proceso clasificado como crítico tiene sus cinco métricas y la comprobación RTO + WRT ≤ MTPD cumplida; cada punto único de falla de BIA_P06 aparece en B.4 y reaparece en la matriz de riesgos de E.05; el SLE de B.2 es el valor que E.05 multiplica por el ARO; los supuestos de B.5 se varían en tres escenarios y el informe ejecutivo (BIA_P07) declara si la conclusión es robusta o depende de un supuesto.

Las filas marcadas «sin uso» conservan su identificador para no alterar la numeración global: el dato sale ahora de la ficha de datos del cliente, con el rango que el cliente declara, y se somete igual a la sensibilidad. Las tres variables que gobiernan la conclusión se someten a los tres escenarios en BIA_P07, sección 11, y su efecto sobre la frecuencia se retoma en E.05, tabla D.7. El informe ejecutivo declara que la recomendación de tratar el riesgo sobre el entorno SCADA se mantiene en los tres escenarios, y que la única variable que exige validación previa de la dirección es la duración máxima sostenible del procedimiento alterno (dato de la ficha: 12 horas, en un rango de 8 a 16), porque si el valor real se acerca a ocho horas, el MTPD de cuatro horas debe revisarse a la baja.

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A.

Cuando el entregable no declara supuestos, la primera fila lo dice. Los supuestos de B.5 y de BIA_P06 llevan aquí el mismo identificador.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
S-07	Entrevistas, participantes y fechas del levantamiento del BIA.	El perfil no describe personas ni reuniones; registrado en BIA_P01 y en la sección 3 de BIA_P06.
S-11	A igual puntaje decide el mayor costo de indisponibilidad por hora.	P-04 (USD 7 400 por hora) precede a P-02 (USD 2 900), ambos con 2,46; registrado en BIA_P05 y BIA_P06.
S-12	EF de 0,55 en el evento de referencia sobre el SCADA, entre 0,40 y 0,70.	Criterio del dueño del proceso con el costo por día de BIA_P02; tabla B.5 y sección 3 de BIA_P06.
S-14	Presupuesto de seguridad de 2028 y 2029 igual al de 2027, entre USD 300 000 y 600 000.	La ficha deja esos dos años sujetos a aprobación de la Junta Directiva; tabla B.5 y sección 3 de BIA_P06.
S-06, S-08, S-09, S-10 y S-13	Sin uso: los datos que registraban salen de la ficha de datos del cliente o se derivan de ella.	Tabla B.5 y sección 3 de BIA_P06; los identificadores se conservan para no alterar la numeración global S-01 a S-17.

Cierre de la consolidación

El puntaje ponderado de BIA_P05, con la escala y los pesos que la dirección aprobó antes de calcular, confirma como críticos dos de los cuatro procesos que el perfil del catálogo declara críticos, P-01 y P-03, y clasifica como importantes a P-04 y P-02, con 2,46. La consolidación entrega a los entregables siguientes: los dos procesos críticos y los cinco importantes como censo para el inventario de activos de E.04; los doce puntos únicos de falla y brechas de B.4 como vulnerabilidades de la matriz de riesgos de E.05; y los seis valores de pérdida por evento único de B.2, SLE-01 a SLE-06, como insumo de la cuantificación de la tabla D.6. Ningún cálculo de frecuencia se hace aquí: esa es la frontera del análisis de impacto y así queda declarada en BIA_P07, sección 7.